

Proyecto Final 800 IDGS

DESARROLLO WEB PROFESIONAL

DESCRIPCIÓN GENERAL DEL PROYECTO

El proyecto es el denominado “Don Galleto”, el cual representa a una empresa que se dedica a la producción y venta de galletas, el sistema deberá ser capaz de controlar las ventas de productos, compras de materias primas y producción de artículos. Para este fin se empleará el framework Flask o Django de Python (NO se permite el uso y consumo de API's), la base de datos se empleará en el DBMS MySQL. Se autoriza el uso de herramientas como Bootstrap, Tilly, etc. NO se puede usar frameworks de Frontend como VUE, etc.

PROCESOS INTERNOS DE NEGOCIO

Actualmente se producen 10 variedades de galletas, estas se pueden vender por cantidad (piezas), por gramos o en dos presentaciones pre empacadas que son de 1kg y 700 grs.

Al comprar materia prima se deberá de modificar la existencia adecuando la cantidad en la medida correcta (Ej. 1 bulto de harina → 50 kilogramos → 50,000 gramos). En cada materia prima deberá de contener un % de merma ya sea por producción (durante el proceso de elaboración) y producto de venta caducado (ya elaborado).

Es importante que se tenga el cuidado de las fechas de caducidad de las materias primas, para que notifique en pantalla cuando alguna este por caducarse.

Al momento de producir un determinado tipo de galleta la receta estará establecida para una cantidad ya determinada de galletas, por lo que cuando se de inicio a la producción deberán disminuir los insumos respecto a los ingredientes que se encuentran en las recetas.

Es importante que el área de venta pueda ver lo que resta en producción y en su caso solicitar que alguna variedad de galleta sea producida.

Cuando sale de producción una tanda / horneada en automático estas existencias se cargan a las existencias de los productos listos para vender, toda la galleta tendrá una fecha de caducidad, en caso de acercarse a la misma 2 días antes se deberá de notificar para sacar de inventario de venta y proceder a almacenarse como merma.

Es importante tener en cuenta que los clientes podrán registrarse y levantar ordenes sobre pedido para comprar desde un portal, podrán seleccionar las galletas que van a comprar y establecer la fecha en la que podrán pasar a recogerlas. El descuento al inventario del producto terminado será contra entrega. Estos pedidos deberán visualizarlos el área de ventas para que pueda mandar a producción si es que no hay existencias suficientes.

Para esto deberá contar con los siguientes módulos funcionales:

- a. Dashboard de:
 - a. Ventas diarias
 - b. Productos más vendidos
 - c. Presentaciones más vendidas
- b. Login de Acceso

- c. CRUD de Usuarios
- d. CRUD de Proveedores
- e. CRUD de Clientes
- f. CRUD de Recetas
- g. Inventario de materias primas
 - a. Sección de salida de efectivo por pago a proveedores
- h. Inventario de producto terminado
- i. Módulo de Producción (transformación de la materia prima)
- j. Módulo de solicitud de producción
- k. Módulos de venta
 - a. Listado de ventas realizadas
 - b. Sección de corte de ventas diario. Registro de ventas. Deberá poder acceder al detalle de venta que será generado por medio del ticket si es necesario o requerido por el cliente, será impreso, pero siempre almacenado en BD.
 - c. Lista de pedidos de clientes realizadas por el portal (personal de ventas)
- l. Portal del cliente.
 - a. Registro en la plataforma
 - b. Registro de pedidos nuevos (carrito de compras).
 - c. Listado de compras realizadas (histórico de compras)

SEGURIDAD EN EL DESARROLLO DE APLICACIONES

1. CADA EQUIPO DEBERÁ ELABORAR LA SIGUIENTE DOCUMENTACIÓN:

- a) Propuesta de proyecto (Describir bien la Empresa y procesos implementados)
- b) Documento de Requerimientos (Funcionales, No Funcionales y de Seguridad)
- c) Evaluación de Riesgos (Matrices de Riesgos)
- d) Casos de uso y Abuso
- e) Presentar el resultado obtenido de aplicar al menos dos herramientas para comprobar la seguridad de aplicaciones Python tales como:
 - Pyup
 - LGTM
 - Python Taint
 - Bandit
 - WAScan
 - SQLmap
 - Spaguetti
 - XSScrapy

2. EN CUANTO AL FUNCIONAMIENTO DE LA APLICACIÓN SE EVALUARÁ

- Sistema de Control de Acceso
 - Autenticación
 - Autorización
 - Administración
- Implementación del principio de mínimo privilegio.
 - Instalar la aplicación con los privilegios adecuados (Configuración, Permisos de Carpeta etc.)

- No utilizar la cuenta de administrador del servidor de base de datos.
- Validación de las entradas de usuario.
- Contar con un buen manejo de errores.

3. CONTROL DE VULNERABILIDADES BASADOS EN EL OWASP TOP TEN (VER ANEXO)

ANEXO

OWASP TOP TEN

- ✚ A01:2021 - Pérdida de Control de Acceso
 - Los usuarios no podrán acceder a las pantallas y métodos de API privados si no se ha iniciado sesión
 - Los usuarios no podrán acceder a las pantallas y métodos de API privados si su rol no cuenta con los privilegios requeridos
 - Deberá evitarse utilizar el nombre de rutas por defecto como podrían ser “/usuarios”, “/admin”
- ✚ A02:2021 - Fallas Criptográficas
 - En la base de datos las contraseñas deberán estar encriptadas.
 - En caso de implementar una arquitectura FRONT-API deberán implementarse estándares de autenticación de token como JWT, bajo ningún motivo deberá utilizarse una autenticación básica que implique el envío del usuario y contraseña en texto plano.
- ✚ A03:2021 – Inyección
 - Deberán implementarse medidas de prevención de inyección SQL como la parametrización o el uso de un ORM al momento de realizar las operaciones con la base de datos
 - Deberán implementarse medidas de prevención de inyección de código como la sanitización de los inputs.
 - En las pantallas donde se realice la subida de archivos deberán restringirse las extensiones válidas tales como PDF, JPG, PNG, JPEG.
- ✚ A04:2021 - Diseño Inseguro
 - Deberá contarse con la declaración específica de los requerimientos de seguridad y reglas de negocio pertinentes para el sistema
- ✚ A05:2021 - Configuración de Seguridad Incorrecta
 - Deberá crearse para la aplicación un usuario de la base de datos que no cuente con permisos de modificación de estructuras, así como estar restringido al uso únicamente de la base de datos de la aplicación. Bajo ningún motivo deberá tenerse habilitados usuarios como ROOT, ADMIN, ANÓNIMO o cualquier usuario por defecto conocido del sistema gestor de base de datos.
 - Al presentarse un error no deberá mostrarse mensajes donde se exponga nombres de clases, directorios, variables, configuraciones o líneas de código de la aplicación.
 - Al presentarse una ruta o un documento que no exista no deberá mostrarse mensajes donde se exponga nombres de clases, variables o líneas de código de la aplicación
 - No deberán mostrarse los archivos contenidos de ningún directorio si se intenta acceder directamente desde la URL
- ✚ A06:2021 - Componentes Vulnerables y Desactualizados
 - Deberá entregarse un plan de seguridad para verificación de actualizaciones de seguridad del sistema de despliegue (servidor, sistema operativo, etc.)
- ✚ A07:2021 - Fallas de Identificación y Autenticación
 - Política de contraseñas seguras. Mínimo 8 caracteres, 1 mayúscula, 1 minúscula, 1 número, 1 carácter especial.

- Contrastar contraseñas con lista de contraseñas inseguras.
- Implementar captcha en inicio de sesión
- Implementar autenticación de 2 pasos. Donde se proporcione un toque de un solo uso y con un tiempo de expiración
- Bloqueo después de 3 intentos fallidos
- Solicitud de cambio de contraseña periódica
- Registro y visualización en pantalla del último inicio de sesión realizado
- Tiempo definido de sesión. La sesión y/o tokens deberán tener una duración máxima de 10 minutos

 A08:2021 - Fallas en el Software y en la Integridad de los Datos

- Reporte de la seguridad y reputación de las librerías instaladas (por ejemplo, implementando la herramienta Pip-audit para proyectos en python)

 A09:2021 - Fallas en el Registro y Monitoreo

- Deberán registrarse en un archivo de logs o en base de datos los errores presentados en la aplicación. Los datos mínimos deberán ser el error presentado y la fecha
- Deberán registrarse en un archivo de logs o en base de datos movimientos críticos del sistema como cualquier cambio realizado en los usuarios

 A10:2021 - Falsificación de Solicitudes del Lado del Servidor

- Deberá implementarse en los formularios que no implementan peticiones asíncronas el uso del token de seguridad CSRF TOKEN
- Deberá implementarse en el uso de peticiones asíncronas la configuración de peticiones cruzadas CORS restringiendo las solicitudes únicamente al nombre de dominio de la aplicación.